



Summary of the Opinion of the European Data Protection Supervisor on the Proposal for a Regulation on payment services in the internal market and the Proposal for a Directive on payment services and electronic money services in the Internal Market

(C/2023/1019)

(The full text of this Opinion can be found in English, French and German on the EDPS website <https://edps.europa.eu>)

On 28 June 2023, the European Commission issued a Proposal for a Regulation of the European Parliament and of the Council on payment services in the internal market and amending Regulation (EU) No 1093/2010 (the 'PSR Proposal') and a Proposal for a Directive of the European Parliament and of the Council on payment services and electronic money services in the Internal Market amending Directive 98/26/EC, and repealing Directives 2015/2366/EU and 2009/110/EC (the 'PSD3 Proposal'), together 'the Proposals'.

Payment services often involve processing of personal data which can reveal sensitive information about an individual data subject. The EDPS therefore welcomes the efforts made to ensure consistency with the General Data Protection Regulation ⁽¹⁾ ('GDPR'). He also stresses the need to clearly differentiate the 'permissions' under Proposal from and the legal basis for processing of personal data under the GDPR.

One of the aims of the Proposal is to enable providers of payment systems and of payment services to process special categories of personal data in the public interest of the well-functioning of the internal market for payment services. As the processing of such data is liable to constitute a serious interference with the rights to respect for private life and to the protection of personal data, it is important that legislation be precise enough to show the objective connection between each category of data in a specific payment context and the public interest objective to be achieved.

The EDPS welcomes that the Proposal would require account servicing payment service providers ('ASPSPs') to provide the user with a dashboard to monitor and manage the permission she or he has granted. To further reduce the risk of unlawful sharing of personal data by ASPSPs, the EDPS recommends:

- ensuring that the dashboard makes reference to the specific designated payment service(s) for which she or he granted her/his permission;
- ensuring that access requests remain limited to what is necessary to provide the requested service;
- ensuring clarity regarding the legal basis of access requests;
- allowing ASPSPs to verify the permission granted by the payment service user or to introduce appropriate alternative safeguards in the PSR Proposal.

Finally, the EDPS recommends ensuring close cooperation between competent authorities under the Proposal and data protection supervisory authorities to ensure consistency between the application and enforcement of the Proposal and EU data protection law. The EDPS therefore recommends expressly referring to supervisory authorities responsible for monitoring and enforcing data protection law in Article 93(3) of the PSR Proposal.

⁽¹⁾ Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1).

1. Introduction

1. On 28 June 2023, the European Commission issued a Proposal for a Regulation of the European Parliament and of the Council on payment services in the internal market and amending Regulation (EU) No 1093/2010 (the 'Payment Services Regulation Proposal' or 'PSR Proposal') ⁽²⁾ and a Proposal for a Directive of the European Parliament and of the Council on payment services and electronic money services in the Internal Market amending Directive 98/26/EC, and repealing Directives 2015/2366/EU and 2009/110/EC (the 'Payment Services Directive 3 Proposal' or 'PSD3 Proposal') ⁽³⁾, hereinafter referred together as 'the Proposals'.
2. Three Annexes accompany both the PSR Proposal and the PSD3 Proposal (six Annexes in total), outlining the types of payment services (Annex I), as well as the type of electronic money services (Annex II) falling under the scope of the draft Proposals. Finally, Annex III provides a correlation table on the provisions of Directives 2015/2366/EU and 2009/110/EC with the provisions in the Proposals.
3. The EDPS notes that the types of services covered by the Proposals seem to be essentially the same as the ones covered by Directive (EU) 2015/2366 of the European Parliament and of the Council of 25 November 2015 on payment services in the internal market, amending Directives 2002/65/EC, 2009/110/EC and 2013/36/EU and Regulation (EU) No 1093/2010, and repealing Directive 2007/64/EC ('PSD2') ⁽⁴⁾.
4. The specific objectives of the PSR Proposal ⁽⁵⁾ are to:
 - (a) strengthen user protection and confidence in payments, notably by: improving the application of Strong Customer Authentication (SCA); creating a legal basis for exchange of information on fraud; extending International Bank Account Number ('IBAN') verification to all credit transfers; and improving user rights and information;
 - (b) improve the competitiveness of open banking services by: (i) requiring account servicing payment service providers ('ASPSPs') to put in place a dedicated data access interface and 'permissions dashboards' to allow users to manage their granted open banking access permissions; and (ii) setting out more detailed specifications of minimum requirements for open banking data interfaces;
 - (c) improve enforcement and implementation of the legal framework for payment services in Member States, notably by: replacing the PSD2 with a directly applicable Regulation ('PSR Proposal') clarifying aspects of the PSD2 which are unclear; and improving cooperation between competent authorities and other authorities; and
 - (d) improve (direct or indirect) access to payment systems and bank accounts for non-bank PSPs, including payment initiation service providers (PISPs) and account initiation service providers (AISPs).
5. The Proposals are presented in conjunction with the Proposal for Regulation on Financial Information Data Access ('the FIDA Proposal') ⁽⁶⁾, covering among others access to financial data other than payment account data, which falls under the scope of the Proposals that form the subject matter of the present Opinion ⁽⁷⁾.
6. In essence, the PSR Proposal would:
 - (a) establish requirements on transparency of conditions and information requirements for payment services ⁽⁸⁾;

⁽²⁾ COM(2023) 367 final.

⁽³⁾ COM(2023) 366 final.

⁽⁴⁾ Directive (EU) 2015/2366 of the European Parliament and of the Council of 25 November 2015 on payment services in the internal market, amending Directives 2002/65/EC, 2009/110/EC and 2013/36/EU and Regulation (EU) No 1093/2010, and repealing Directive 2007/64/EC (OJ L 337, 23.12.2015, p. 35).

⁽⁵⁾ COM(2023) 367 final, page 5-6.

⁽⁶⁾ COM(2023) 360 final.

⁽⁷⁾ COM(2023) 367 final, page 4.

⁽⁸⁾ Articles 4-26 of the PSR Proposal.

- (b) establish rights and obligations in relation to the provision and use of payment services, including rules on data access interfaces for account information services and payment initiation services ⁽⁹⁾ and on data access management by payment service users ⁽¹⁰⁾; on data protection ⁽¹¹⁾; on fraud reporting and transaction monitoring mechanisms and fraud data sharing ⁽¹²⁾; on SCA ⁽¹³⁾; on enforcement procedures, competent authorities and penalties ⁽¹⁴⁾; on intervention powers by the European Banking Authority (EBA) ⁽¹⁵⁾.
7. The PSD3 Proposal is largely based on Title II of the current PSD2, regarding 'Payment Service Providers', which only applies to payment institutions. It updates and clarifies the provisions relating to payment institutions and integrates electronic money institutions as a sub-category of payment institutions. It also includes provisions concerning cash withdrawal services provided by retailers or independent ATM deployers ⁽¹⁶⁾.
8. The present Opinion of the EDPS is issued in response to a consultation by the European Commission of 29 June 2023, pursuant to Article 42(1) of EUDPR. The EDPS welcomes the reference to this consultation in Recital 147 of the PSR Proposal and Recital 77 of the PSD3 Proposal. In this regard, the EDPS also positively notes that he was already previously informally consulted on the Proposals pursuant to Recital (60) of the EUDPR.

12. Conclusions

52. In light of the above, the EDPS makes the following recommendations:

- (1) to clearly differentiate between the term 'permission' and the legal basis for processing under the GDPR, by clarifying in Recital 62 of the PSR Proposal that 'permission should not be construed as "consent" or "explicit consent" or "necessity for the performance of a contract" as defined in Regulation (EU) 2016/679';
- (2) to clarify, by way of a recital, that the granting of permission by the payment service user is without prejudice in particular to the obligations of payment initiation service providers and account information service providers under Article 6 and Article 9 of Regulation (EU) 2016/679;
- (3) to reconsider the prohibition applicable to ASPSPs to verify the permission under Article 49(4) of the PSR Proposal or to introduce appropriate alternative safeguards in the enacting terms of the PSR Proposal to protect payment service users against the risk of potential unlawful sharing of personal data by ASPSPs that this prohibition may entail;
- (4) to amend Articles 46(2)(a) and 47(2)(a) of the PSR Proposal to state that payment initiation service providers and account information service providers shall not access personalised security credentials;
- (5) to clarify the definition of 'sensitive payment data' under Article 3(38) of the PSR Proposal, notably specifying the types of personal data covered by this definition;
- (6) to specify in relation to which specific type(s) of designated payment service(s) the payment systems and the payment service provider would be entitled to process (which categories of) special categories of personal data in Article 80 of the PSR Proposal;
- (7) to provide justifications (in a recital) as to why the processing of the special categories of personal data for the designated payment service(s) in Article 80 of the PSR Proposal is necessary and proportionate and cannot be avoided via alternative technical means;
- (8) to include a reference to log in registration (to verify if undue access took place) among the data protection safeguards referred to in Article 80 of the PSR Proposal;

⁽⁹⁾ Articles 35-38 of the PSR Proposal.

⁽¹⁰⁾ Article 43 of the PSR Proposal.

⁽¹¹⁾ Article 80 of the PSR Proposal.

⁽¹²⁾ Articles 82-84 of the PSR Proposal.

⁽¹³⁾ Articles 85-86 of the PSR Proposal.

⁽¹⁴⁾ Chapter 8 of the PSR Proposal.

⁽¹⁵⁾ Chapter 9 of the PSR Proposal.

⁽¹⁶⁾ COM(2023) 367 final, page 7.

- (9) to add to Article 43(2)(a) a reference to the designated payment service(s) for which the permission is granted by the payment service user;
- (10) to add to Article 47(2), concerning the obligations of account information service providers, the requirement under Article 46(2)(b), according to which payment service providers can request from the payment service user only the data that are necessary to provide the requested service;
- (11) to require payment service providers and account information service providers under Article 43(4)(b) to inform account servicing payment service providers about the customer account to which access is being sought and about the legal basis under Article 6(1) GDPR and (if applicable) the exception under Article 9(2) GDPR that they would rely on to access the personal data of the payment service user;
- (12) to specify in Article 43(b) that the dashboard should not be designed in a way that would encourage or unduly influence payment service users to grant or withdraw permissions;
- (13) to clearly determine the categories of personal data that payment service providers would be allowed to process in the context of transaction monitoring mechanisms (notably, providing a definition of 'information on the payment service user' referred to in Article 83(2)(a));
- (14) to define appropriate data storage periods for the personal data collected under Article 83;
- (15) to include a definition of 'information sharing agreement' in Article 3 of the PSR Proposal;
- (16) to provide in the PSR Proposal that any processing of personal data for the purpose of complying with the fraud prevention legal obligations under Article 83 can only occur for this specific purpose and cannot lead to termination of customer relationship with the payment service provider or affect the on-boarding of the payment service user with another payment service provider;
- (17) to explicitly mention supervisory authorities responsible for monitoring and enforcing data protection law in Article 93(3) of the PSR Proposal.

Brussels, 22 August 2023.

Wojciech Rafał WIEWIÓROWSKI
